INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Incident Response Planning Assignment

GRC105 Incident Management and Business Continuity Week 20

Student Name: JOY ORILADE

Student ID: 2025/GCR/2512719

Email Address: gcr2512719@students.icdfa.edu.ng

Date: 19th October 2026

Instructor: Com Idris Aminu

Scenario and evidence

Northbridge Skills Institute

Northbridge Skills Institute is a fictional education and training provider with 1,800 learners and 90 staff. It holds learner contact details, admission documents, assessment records, and finance files. An online examination for 100 learners is scheduled for 11:00 on Day 0. You take control of the incident at 08:45 on Day 0, a Monday. All times are West Africa Time (WAT).

Its systems are FIN-PC07, a finance workstation; FS01, the shared file server; LMS01, the learning portal; and BAK01, the network backup repository. Microsoft 365 provides identity and email. The portal depends on files stored on FS01. The svc_backup account has administrator access to FS01 and BAK01.

The last disconnected backup is from 17:00 on Day minus 3, the preceding Friday. Network backups are not immutable. Neither backup route has undergone a restoration test in the last 90 days. EDR covers workstations, but server coverage is incomplete. The IT team has three staff and one security analyst.

Initial evidence pack

ID	Time WAT	Source and observation
E01	Day minus 1 16:40	User report and mail record: a finance officer opened an unexpected payroll attachment on FIN-PC07. Execution of malicious code is not yet verified.
E02	Day 0 01:15	Microsoft 365 audit: the finance officer account signed in from an unfamiliar IP and new device. MFA status and the user's involvement are unknown.

E03	Day 0 01:35	Windows logs: svc_backup made remote administrator logons to FS01 and BAK01 outside its usual schedule. The reason is unknown.
E04	Day 0 01:50	Proxy record: FIN-PC07 uploaded 1.2 GB over HTTPS to unfamiliar cloud storage. The record does not reveal the transferred content.
E05	Day 0 02:00	Backup console: the FS01 and LMS01 job reports success. Recoverability and freedom from compromise have not been established.
E06	Day 0 08:30	EDR and helpdesk: mass file changes occur on FIN-PC07. FS01 shared folders contain .locked files and a ransom note. The malware family is unconfirmed.
E07	Day 0 08:40	Helpdesk: the portal login page loads, but learners cannot open materials or submit assessments. The scope of damage to LMS01 remains unknown.
E08	Day 0 08:45	Operations report: the incident contact list on FS01 is inaccessible. Staff phones are available. The trustworthiness of corporate email is unverified.

These observations do not establish attacker identity or prove that personal data was stolen. Cite evidence IDs in your decisions and label additional assumptions. Use fictional contact details and record proposed evidence collection as planned.

Incident assessment and governance

Task 1 Incident classification and initial assessment

A. Create a timeline using E01 to E08. Separate confirmed observations, working hypotheses, and unresolved questions. Explain at least two plausible alternative explanations for ambiguous events.

ANSWER

ID / time (WAT)	Source	Confirmed observation	Working hypothesis	Unresolved question
E01 Day −1 16:40	User report and mail record	Finance officer opened an unexpected payroll attachment on FIN-PC07.	Phishing delivered a malicious payload; likely initial access vector.	Did the attachment execute code, and did it establish persistence or command-and-control?
E02 Day 0 01:15	Microsoft 365 audit	Finance officer account signed in from an unfamiliar IP and a new device.	Credentials or session token were stolen (possibly via E01) and used by the attacker.	Was MFA satisfied or bypassed? Was the user travelling, using a VPN or a new device? What did the session access?

E03 Day 0 01:35	Windows logs	svc_backup made remote administrator logons to FS01 and BAK01 outside its usual schedule.	Attacker obtained and used the privileged service account to reach the file server and backups.	Source host of the logons? Any approved change? Were backup jobs, snapshots or retention settings altered?
E04 Day 0 01:50	Proxy record	FIN-PC07 uploaded 1.2 GB over HTTPS to unfamiliar cloud storage; content not visible.	Data staged and exfiltrated before encryption (double-extortion pattern).	What was transferred, from which source files, by which process and account?
E05 Day 0 02:00	Backup console	FS01 and LMS01 backup job reported success.	Job ran after attacker activity (E03) and may contain tampered or pre-encrypted data.	Is the backup recoverable and free from malware or attacker changes?
E06 Day 0 08:30	EDR and helpdesk	Mass file changes on FIN-PC07; .locked files and a ransom note in FS01 shared folders.	Ransomware encryption executed on endpoint and file server.	Which malware family? How far has encryption spread (other shares, LMS01, BAK01)?
E07 Day 0 08:40	Helpdesk	Portal login page loads, but learners cannot open materials or submit assessments.	LMS01 is degraded because the files it depends on in FS01 are encrypted.	Is LMS01 itself compromised, or only its FS01 dependency? Is assessment data intact?
E08 Day 0 08:45	Operations report	Incident contact list on FS01 inaccessible; staff phones available; corporate email trust unverified.	Contact list is among encrypted FS01 content; email may be observed by the attacker (links to E02).	Is the M365 tenant compromised? Is an offline copy of contacts available?

- Explain at least two plausible alternative explanations for ambiguous events.

E02 – legitimate remote access or credential theft. The unfamiliar IP and new device could reflect the officer working late from a personal device, travelling or using a commercial VPN. Against this, the sign-in occurred about eight and a half hours after a suspicious attachment was opened (E01) and twenty minutes before anomalous privileged activity (E03). The legitimate explanation is plausible but cannot be accepted without the officer's confirmation and the MFA record.

E03 – rescheduled backup activity or service account abuse. The out-of-schedule logons may be a manually triggered or rescheduled job, or an administrator using the account for maintenance. Its timing, 25 minutes before E05, could even be consistent with a legitimate pre-job check. However, svc_backup holds administrator rights on both FS01 and BAK01, which is exactly the access an attacker would seek to disable recovery before encryption (CISA et al., 2023). Until a change record is produced, the account is treated as compromised.

B. Classify the incident type and initial severity. Define the criteria for Critical, High, Medium, and Low severity, then justify the selected level using operational impact, affected data, and uncertainty.
ANSWER

Incident Type: The incident was classified as a suspected ransomware and cyber-extortion incident, involving:

- Confirmed ransomware-related indicators on FIN-PC07 and FS01.
- Disruption of the learning portal and assessment activities.
- Possible compromise of a finance user account.
- Suspicious privileged access to the file server and backup repository.
- Possible data exfiltration through the 1.2 GB outbound transfer.
- Uncertain backup integrity and recovery capability.

The attacker, malware family and initial access route remain unconfirmed.

Severity criteria

Severity	Classification Criteria
Critical	Multiple critical systems or services are affected; there is active destructive activity, major business disruption, or a credible risk to privileged systems, backups or sensitive data. Immediate coordinated response is required.
High	A significant system or service is affected, but the incident appears contained and the impact on other critical services is limited. Prompt response and management oversight are required.
Medium	The incident has limited operational impact, affects a restricted set of assets and can be contained without substantial interruption to essential services.
Low	The event has negligible operational impact, with no credible evidence of significant compromise, data exposure or service disruption.

The initial severity is Critical, justified on three grounds.

Operational impact. Encryption on FS01 (E06) has broken LMS01 functions that learners need (E07), and an online examination for 100 learners is scheduled for 11:00, just over two hours after the IRL took control. The incident contact list is also unavailable (E08), weakening coordination for a small team of three IT staff and one analyst.

Affected data. FS01 and the backups hold or support learner contact details, admission documents, assessment records and finance files. A 1.2 GB upload (E04) and a possibly compromised finance identity (E02) mean exposure of sensitive data is credible, although not confirmed.

Uncertainty. The most important uncertainties are whether svc_backup and the network backups are compromised (E03, E05) and whether email can be trusted (E08). These could each extend the outage or the scope of a breach, so they increase, rather than reduce, the severity assigned. Network backups are not immutable, neither backup route has been restore-tested in 90 days, and server EDR coverage is incomplete, so a quick and certain recovery cannot be assumed. Severity will be reassessed at each update point and whenever investigation questions Q1–Q5 are answered. A downgrade to High would require evidence that the exfiltrated content was non-sensitive and that a clean, validated backup exists.

C. Identify confirmed and potentially affected assets. Assess confidentiality, integrity, and availability separately. Set response priorities that address the examination deadline and possible backup compromise.

ANSWER

Asset	Confidentiality	Integrity	Availability
FIN-PC07 — Finance workstation	Potentially high risk because of the unexplained 1.2 GB upload (E04). The transferred content is unknown.	High concern due to mass file changes and suspected malicious activity (E01, E06).	High concern because of the mass file changes and need for containment.
FS01 — Shared file server	Potential exposure of learner, finance or other records stored on the server; disclosure is not confirmed.	Confirmed file-encryption indicators, including .locked files and a ransom note (E06).	High impact because shared folders are affected and LMS01 depends on files stored on FS01
LMS01 — Learning portal	Unknown; further investigation is required to establish whether unauthorised access occurred.	Unknown; application and data integrity must be checked.	Confirmed disruption because learners cannot access materials or submit assessments (E07).
BAK01 — Backup repository	Unknown; the scope of access to backup data is not established.	High risk because of unusual privileged logons and the lack of immutable network backups (E03).	Critical to recovery because safe, usable backups have not been established.
Microsoft 365 and finance account	Potential exposure if the account or associated mailbox and cloud files were accessed.	Potential risk if an attacker changed mailbox rules, account settings or records.	Potential disruption if account restrictions are required during containment.

Set response priorities that address the examination deadline and possible backup compromise.

Priority 1: Stop ongoing damage. Isolate FIN-PC07 from the network and restrict FS01 and BAK01 to essential, controlled management access. If encryption or lateral movement is active, containment must not be delayed for extensive evidence collection.

Priority 2: Protect backups. Keep the last disconnected backup from Day −3 offline and prevent backup jobs, replication or administrative activity from overwriting or damaging recovery copies. Do not assume the reported successful jobs are safe (E03, E05).

Priority 3: Secure identities. Investigate the finance account's unusual sign-in, revoke suspicious sessions and tokens, and reset credentials where necessary. Restrict svc_backup while ensuring that any essential backup operations are handled through a controlled, trusted process.

Priority 4: Protect examination continuity. Inform management that the 11:00 examination should be postponed unless a clean, isolated and validated alternative can be made available. The deadline must not override the requirement to protect learner data and system integrity.

Priority 5: Establish trusted coordination. Use verified staff telephone numbers and an out-of-band contact process because the contact list on FS01 is inaccessible and corporate email has not been verified (E08).

Priority 6: Establish the scope of compromise. Determine whether the attacker accessed additional endpoints, privileged accounts, cloud services or learner records. Engage specialist incident-response support if the internal team lacks the required capacity.

D. List at least three priority investigation questions. For each, identify the additional log, artifact, interview, or validation check that could resolve it. Explain what findings would change your severity or scope assessment.
ANSWER

Question	Resolving log / artifact / interview / validation	Findings that change severity or scope
Q1. Did the E01 attachment execute, and is FIN-PC07 the entry point?	EDR process tree and alerts on FIN-PC07; mail gateway message trace and sandbox detonation of the attachment; interview with the finance officer.	Raise scope: execution with persistence or command-and-control, or the same lure delivered to other staff. If there was no execution, look for another entry vector; scope widens and the root cause stays open.
Q2. Was the E02 sign-in the user or an attacker, and was MFA satisfied?	Microsoft Entra ID sign-in logs (MFA detail, device, location); M365 unified audit log for mailbox rules, forwarding, file access and sent mail; interview with the officer about travel or VPN use.	Raise: attacker session, new inbox rules or mass file access, meaning email compromise and wider data and communication risk. Lower: user's new device verified and MFA genuinely satisfied.
Q3. Who used svc_backup at E03, from where, and what changed?	FS01/BAK01 Windows Security logs (logon events, source host, privilege use); backup software audit and job history; change records; interview with IT staff.	Raise: logons sourced from FIN-PC07 or an unknown host, deleted snapshots or altered retention, meaning backups are compromised and the outage is longer. Lower: matches an approved, documented change.

Task 2 Incident response plan and team responsibilities

A. Prepare a concise policy and plan covering mission, objectives, scope, incident declaration, activation and escalation rules, authority to isolate systems, documentation requirements, and plan review. Explain how the plan connects with business continuity.

ANSWER

Establishing the Computer Security Incident Response Team (CSIRT) Plan

Northbridge Skills Institute should establish a Computer Security Incident Response Team (CSIRT) to coordinate the response to the suspected ransomware incident. The team should bring together technical, management, legal, communications and business-continuity representatives.

The incident affects the finance workstation, file server, backup repository and learning management system (LMS). It also involves suspicious account activity and a possible transfer of data to an unfamiliar cloud service. Therefore, the response must address both technical recovery and organisational impact.

Mission. To protect Northbridge's learners, staff and information by detecting, containing and recovering from cybersecurity incidents quickly, in a way that preserves evidence, meets legal obligations and keeps teaching and assessment running.

The CSIRT should work towards the following objectives:

1. Contain the incident: Limit ransomware spread and prevent further unauthorised access.
2. Protect evidence: Preserve relevant logs, affected systems and other evidence for investigation.
3. Protect backups: Prevent backup deletion, encryption or overwriting while their integrity is assessed.
4. Determine the scope: Identify affected accounts, devices, servers, services and potentially exposed information.
5. Maintain essential services: Make decisions about the 11:00 a.m. examination and alternative learning arrangements.
6. Coordinate communication: Provide staff, learners, management and relevant external parties with accurate updates.
7. Recover safely: Restore services only after the affected systems and recovery sources have been assessed as trustworthy.

The team should operate under a designated Incident Commander, with clear authority to coordinate response activities and escalate urgent decisions to senior management.

Scope. All Northbridge staff, contractors and service providers; all institute-owned or managed systems, including FIN-PC07 and other workstations, FS01, LMS01, BAK01, the Microsoft 365 tenant and its identities, and privileged and service accounts such as svc_backup. Physical security incidents and non-cyber business disruptions fall under the business continuity plan (BCP) unless a cyber cause is suspected.

Incident declaration. Anyone may report a suspected event to the IT service desk or the incident hotline. The security analyst triages the report. An incident is declared when there is a confirmed or reasonably suspected breach of confidentiality, integrity or availability, for example malicious code execution, unauthorised account use, unexplained privileged activity or unexplained bulk data transfer. The incident manager confirms the declaration, assigns the initial severity and opens the incident log. When in doubt, the event is declared at the higher plausible level and reviewed

Activation and escalation rules by severity

Severity	Activation	Escalate to	Timing (target)	Review cycle
Critical	Full CSIRT activated; executive sponsor chairs decisions; BCP lead activated; DFIR retainer and insurer notified (A6, A7).	Executive sponsor, business owners, legal/privacy, communications lead.	Within 30 minutes of declaration.	Situation update at least hourly.
High	CSIRT core (incident manager, analyst, IT operations, affected business owner) activated; external support on standby.	Executive sponsor informed; legal/privacy if personal data may be involved.	Within 1 hour.	Every 2–4 hours.
Medium	Security analyst and IT operations handle under incident manager oversight.	Incident manager; business owner of the affected system.	Within 4 hours (business hours).	Daily.
Low	Handled as a routine ticket and logged.	Security analyst.	Next business day.	At closure.

Some triggers require escalation regardless of the current level. Any sign of personal data exposure goes to the legal/privacy adviser immediately. Any compromise of backups or privileged accounts raises the incident to at least High. A ransom demand, an extortion threat or a media enquiry goes to the executive sponsor and the communications lead. Any risk to a scheduled examination or assessment goes to the academic business owner. If the incident manager cannot be reached within 15 minutes, the security analyst acts as deputy (A8).

Authority to isolate systems. The incident manager may, without prior approval, isolate any endpoint, disable or reset any user, service or cloud account, and block network destinations when there is active encryption, active spread, or credible privileged or identity compromise. The security analyst holds the same authority out of hours when acting as deputy. Isolating a business-critical server (FS01, LMS01, BAK01) requires consulting the relevant business owner first, unless encryption or attacker activity is under way; in that case the server is isolated at once and the executive sponsor is informed within 30 minutes. Network isolation is preferred to shutting down, so that volatile evidence is preserved. Where evidence is lost through urgent action, the loss is recorded in the decision log. Decisions on any ransom engagement are reserved to the executive sponsor, advised by legal counsel, the insurer and law enforcement. CISA does not recommend paying a ransom (CISA et al., 2023).

Documentation requirements. Every incident at Medium or above maintains: (a) an incident log of timestamped (WAT) actions; (b) a decision log recording the owner, rationale and evidence ID for each decision; (c) an evidence register and chain-of-custody forms; and (d) a communications log. Records are kept outside the affected environment, on a dedicated encrypted laptop and an offline printed log, because systems such as FS01 and email may be untrustworthy (E08). System clocks are checked against a reliable time source when evidence is collected.

Plan review. The incident manager reviews the plan at least annually, after every High or Critical incident or exercise, and after significant changes to systems, providers or staff. The executive sponsor approves each revision. Version history and the next review date are recorded on the cover page.

Connection with business continuity

The incident response plan (IRP) and the BCP are separate documents with defined handoffs. The IRP manages the cyber incident itself: containment, evidence, eradication and validated recovery. The BCP keeps essential services running while systems are unavailable. A Critical incident affecting a service listed in the business impact analysis automatically activates the BCP lead. In the Northbridge case that service is LMS01 and the scheduled examination (E07). The BCP then owns alternative arrangements, such as postponing the examination or using an approved alternative assessment, so that pressure on availability does not push the CSIRT into restoring from an unverified backup (E05). The two plans share one offline contact list, one set of recovery time and recovery point objectives taken from the business impact analysis (A9), and joint exercises. The business owner joins the CSIRT as the BCP liaison and gives final approval to return a service.

B. Define a Computer Security Incident Response Team (CSIRT) with at least six roles. Include incident management, security analysis, forensics, IT operations or a business owner, legal or privacy advice, and communications. Explain how the small team will obtain additional support when needed.
ANSWER

CSIRT roles for a small team

Role	Assigned to	Core responsibilities	Deputy
Executive sponsor	Principal / Chief Executive	Chairs Critical decisions; approves spending, external support, the examination decision and external statements; owns any ransom decision.	Deputy Principal
Incident manager (IRL)	IT Manager (IT staff 1)	Declares and classifies incidents; coordinates the CSIRT; holds isolation authority; keeps the decision log.	Security analyst
Security analyst	Security analyst	Triage; log, EDR and M365 analysis; scoping; threat containment actions.	External DFIR provider

Forensics lead / evidence custodian	IT staff 3 (custodian) with the retained DFIR provider (analysis)	Planned evidence collection, integrity checks, custody records, secure storage.	DFIR provider
IT operations lead	IT staff 2	Isolation, account resets, backup protection, rebuild and restoration.	IT staff 3
Business owners	Head of Academic Operations (LMS01, exams); Finance Manager (finance data)	Business impact, priorities and continuity workarounds; approve service return.	Nominated deputies
Legal / privacy adviser	Data Protection Officer with external counsel	Assess reporting and notification obligations; advise on evidence, extortion and statements.	External counsel
Communications lead	Marketing and Communications Officer	Draft learner, staff and media messages; run out-of-band channels; monitor social media.	Registry Manager

C. Create a RACI matrix for at least eight activities: detection, analysis, containment, evidence handling, stakeholder communication, assessment of reporting obligations, restoration approval, and closure or review. Define Responsible, Accountable, Consulted, and Informed. Assign exactly one accountable role and at least one responsible role per activity. A combined A/R assignment is acceptable.
ANSWER

Definitions.

- Responsible (R) means the role performs the work.
- Accountable (A) means the single role that owns the outcome and signs off; there is exactly one per activity.
- Consulted (C) means the role gives input before or during the work, in two-way communication. Informed (I) means the role is kept updated on progress or the decision, one way. A/R means the accountable role also performs the work.

RACI matrix (exactly one A and at least one R per row)

Activity	Exec sponsor	Incident mgr	Sec analyst	Forensics	IT ops	Business owner	Legal/ privacy	Comms
1. Detection and reporting	I	I	A/R	–	R	I	–	–
2. Analysis, triage and severity	I	A	R	C	C	C	I	–

3. Containment (incl. isolation)	I	A	R	C	R	C	I	I
4. Evidence handling and custody	–	I	R	A/R	R	–	C	–
5. Stakeholder communication	A	C	I	–	I	C	C	R
6. Assessment of reporting obligations	A	C	C	C	I	C	R	I
7. Eradication and restoration work	I	A	R	C	R	C	–	I
8. Restoration approval (service return)	I	R	C	C	C	A	I	I
9. Closure and post-incident review	A	R	C	C	C	C	C	C

D. Recommend at least four preparation improvements. Include backup readiness and an accessible incident contact list. For each improvement, name the owner, resources needed, and how readiness will be checked. Cover tools, secure communication, and training where relevant.

ANSWER

Readiness checklist

#	Improvement	Owner	Resources needed	Readiness check (evidence)
1	Backup readiness: add an immutable or offline copy of FS01 and LMS01; separate backup administration credentials from production; protect the backup console with MFA.	IT operations lead	Immutable or object-lock storage, or rotated offline media; budget approval; vendor configuration time.	Quarterly isolated restore test of FS01 and LMS01 that meets agreed recovery time and recovery point objectives, with a signed test record; immutability setting verified.
2	Accessible offline incident contact list (CSIRT, deputies, DFIR provider, insurer, Microsoft, MSP, legal, key business owners).	Incident manager	Printed copies in two secure locations; encrypted copy on CSIRT phones; storage outside FS01 and the M365 tenant.	Monthly call-tree test, with all contacts reached within 30 minutes; review date on the list no older than 90 days.

3	Secure out-of-band communication: pre-arranged encrypted messaging group and conference bridge independent of corporate email.	Communications lead	Messaging service licence; CSIRT phones (available per E08); usage guidance.	Channel used successfully in every exercise; membership audited quarterly.
4	Tools and visibility: extend EDR to FS01, LMS01 and BAK01; centralise and retain Windows, M365 audit and proxy logs; prepare a forensic kit.	Security analyst	EDR server licences; log storage; write-blocker, external media and documented collection procedures.	EDR coverage report showing 100% of servers; test query retrieves 90 days of sign-in and logon logs (A11).

Response operations and communication

Task 3 Response playbook and evidence preservation

A. Create a playbook containing at least ten ordered actions for the first 60 minutes after 08:45 and the remainder of the first 24 hours. Use columns for time or stage, action, owner, required approval, evidence to retain, and completion check.

ANSWER

Purpose and Response Priorities

Northbridge Skills Institute is responding to a suspected ransomware incident involving FIN-PC07, FS01, BAK01 and disruption to LMS01. The available evidence includes mass file changes, .locked files, a ransom note, suspicious privileged logons and a 1.2 GB upload to unfamiliar cloud storage. However, the evidence does not yet confirm the attacker's identity, the contents of the uploaded data or whether the backups are safe.

The objective of this playbook is to contain the incident, preserve evidence, determine the full scope of compromise and restore essential services safely.

The response will follow four teaching stages: preparation; detection and analysis; containment, eradication and recovery; and post-incident activity. These are the assignment's teaching stages; they should not be presented as the exact lifecycle wording of NIST SP 800-61 Revision 3.

The immediate priorities are to:

1. Isolate affected systems where necessary to prevent further damage.
2. Protect BAK01 and the disconnected Day −3 backup.
3. Secure potentially compromised accounts, including the finance account and svc_backup.
4. Preserve relevant evidence before it is lost or altered, where doing so does not delay urgent containment.
5. Determine whether the 1.2 GB transfer involved sensitive or personal information.
6. Make a safe, evidence-informed decision about the 11:00 a.m. examination.

7. Restore services only after validating the recovery source and checking for continuing compromise.

B. Cover short term containment, investigation, longer term containment, eradication, recovery, and closure. Address affected endpoints, privileged and cloud accounts, the shared server, suspicious transfers, and backup access. Explain how you will check for broader compromise.

ANSWER

This playbook puts into practice the containment, eradication and recovery stage. In NIST SP 800-61 Revision 3 terms it spans the CSF 2.0 Respond function (incident management, analysis, mitigation and reporting) and the Recover function (recovery plan execution and communication) (Nelson et al., 2025; NIST, 2024). The sequence follows the #StopRansomware response checklist: isolate affected systems, protect backups, preserve evidence, scope the compromise, and only then eradicate and restore (CISA et al., 2023). The incident remains Critical (Task 1). Owners are the CSIRT roles defined in Task 2, and approvals follow the isolation authority.

Playbook: First 60 minutes and first 24 hours

The Response playbook table orders the actions. Rows 1–9 cover the first 60 minutes (08:45–09:45) and are dominated by short-term containment and protecting recovery options. Rows 10–17 cover the rest of the first 24 hours. Row 18 sets out closure, which falls outside the 24-hour window but is planned now. Times are targets; actual times are recorded in the incident log.

Response playbook (Day 0, from 08:45 WAT)

# / time (WAT) / stage	Action	Owner	Required approval	Evidence to retain	Completion check
1 08:45–08:50 Activation	Declare a Critical incident; open the offline incident and decision logs; activate the CSIRT and the BCP lead by staff phone (E08).	Incident manager	None (Section 2.1); executive sponsor informed	Incident log entry; call record	All CSIRT roles acknowledge by 09:15
2 08:50–09:00 Short-term containment	FIN-PC07: collect EDR triage and volatile data, then apply EDR network containment. Keep the device powered on (E01, E04, E06).	Security analyst	None: active encryption (E06)	EDR alerts, process tree, memory capture (EV-01)	EDR shows host contained; no new file changes
3 08:50–09:05 Short-term containment	FS01: isolate at switch or firewall and end SMB sessions; keep powered on; take a snapshot first if virtualised (A12).	IT operations lead	Incident manager; business owner (Academic) informed: LMS01 goes fully offline	Ransom note, sample .locked files, Windows logs (EV-05)	No active sessions; .locked file count stable

4 09:00–09:10 Short-term containment	Backups: disable svc_backup; suspend all BAK01 jobs so they do not overwrite earlier restore points; limit BAK01 to console access only; confirm the Day −3 offline backup stays disconnected and under custody (E03, E05).	IT operations lead	Incident manager	Backup job history and configuration export (EV-06)	Account disabled; no jobs running; offline media logged in custody
5 09:00–09:15 Short-term containment	Finance officer M365 account: export sign-in and audit logs first, then revoke sessions, reset the password, block sign-in and require MFA re-registration (E02).	Security analyst	Incident manager; Finance business owner informed	Sign-in and unified audit log export (EV-03)	No active sessions; sign-in blocked
6 09:10–09:20 Short-term containment	E04 transfer: preserve proxy and firewall logs; block the destination at proxy and firewall; identify the storage provider.	Security analyst	Incident manager	Proxy and firewall logs (EV-04)	Block confirmed; no new connections
7 09:15–09:35 Investigation	First scoping hunt: EDR search on all workstations for the E01 attachment, .locked files, ransom note name and the E04 destination; Windows logs for svc_backup logons on other hosts.	Security analyst	None	Hunt queries and results	Preliminary affected-host list in the log
8 09:20–09:45 Recovery planning / continuity	Examination decision: the business owner presents options (Section 3.2); the executive sponsor decides; the communications lead prepares the learner notice (Task 4).	Business owner (Academic)	Executive sponsor	Decision log entry with rationale	Decision recorded by 09:45 (A3)
9 09:30–09:45 Investigation support	Engage the DFIR provider and, if a policy exists, the insurer; brief the legal/privacy adviser on possible personal data exposure (E04).	Incident manager	Executive sponsor (spending, A10)	Engagement record	DFIR arrival time confirmed (A13)
10 09:45–12:00 Investigation	Forensic acquisition per the evidence register (Table 11): FIN-PC07 disk, FS01 logs and volume, E01 email.	Forensics lead	Incident manager	EV-01 to EV-07; custody forms	SHA-256 recorded at acquisition; custody forms signed

11 10:00–15:00 Investigation (broader compromise)	Scope checks on identity, endpoints, servers and data (Section 3.1.1).	Security analyst with DFIR	None	Query outputs; scoping report v1	Scoping report issued to the incident manager
12 12:00–17:00 Longer-term containment	Credential containment: create a new least-privilege backup account; reset privileged and service account passwords; reset krbtgt twice if on-premises AD exists (A14); block legacy authentication; enforce MFA conditional access.	IT operations lead	Incident manager; executive sponsor informed of disruption	Change and reset log	No successful logons with old credentials
13 12:00–20:00 Recovery (validation)	Backup validation in an isolated recovery environment: mount the Day −3 offline backup and the E05 backup read-only; scan; compare; test-restore samples.	IT operations lead with forensics lead	Incident manager	Validation record; scan reports	Validation report naming a candidate restore point
14 14:00–20:00 Eradication	Remove persistence found in scoping; rebuild FIN-PC07 from a known-good image after imaging; block the E01 sender and attachment and purge matching messages.	IT operations lead	Incident manager; forensics lead confirms evidence acquired	Rebuild record; mail purge log	Clean EDR scan; no indicator matches
15 16:00–Day +1 06:00 Recovery	Rebuild FS01 on a clean host and restore validated data in the isolated segment; then LMS01 (restoration order, Section 3.4).	IT operations lead	Incident manager (start); business owner (return to service)	Restore logs; integrity checks	Acceptance criteria (Table 13) tested
16 18:00–24:00 Investigation / reporting	Assess what E04 contained and whether notification obligations apply (Task 4).	Legal/privacy adviser	Executive sponsor	Written assessment	Obligations and deadlines documented
17 20:00–Day +1 08:45 Monitoring / handover	Heightened monitoring of EDR, M365 and proxy; shift handover; 24-hour situation report.	Incident manager	Executive sponsor receives report	Situation report; handover notes	Report issued by Day +1 08:45
18 After Day +1 Closure (planned)	Close when acceptance criteria are met and 14 days of monitoring are clean; run the	Incident manager	Executive sponsor	Final report; lessons log	Closure signed; actions assigned

	post-incident review within 10 working days.				

C. Justify two difficult decisions: containment while preserving useful evidence, and restoring examination access while backup safety is uncertain. Explain when immediate isolation is necessary and how you will document any evidence loss or operational impact.

ANSWER

Decision 1: Containment while preserving evidence

Immediate isolation is necessary when harm is still under way: active encryption, active exfiltration, or misuse of privileged or cloud accounts. At 08:45 E06 shows active encryption on FIN-PC07 and FS01, and E03 suggests privileged misuse, so delaying containment to collect perfect evidence is not justified. The choice is in how to isolate. Network isolation through EDR or switch controls stops spread while keeping memory, running processes and open connections available. Powering down would destroy that volatile evidence and could corrupt files being encrypted. CISA advises disconnecting affected devices and powering them down only if they cannot be disconnected (CISA et al., 2023). Where it does not delay isolation by more than a few minutes, the analyst captures EDR triage data and memory first (row 2). Otherwise isolation comes first, and volatile capture is attempted afterwards through EDR live response.

Isolation has costs. It may alert the attacker. It ends live command-and-control traffic that could have identified infrastructure. Isolating FS01 takes LMS01 fully offline, worsening E07. Each such decision is recorded in the decision log with the time (WAT), the decision owner, the trigger evidence ID, the evidence knowingly given up (for example "FS01 memory not captured; host not virtualised"), and the operational impact with the business owner's acknowledgement. Recording evidence loss openly protects the credibility of later findings, including any claim about whether data was stolen.

Decision 2: Restoring examination access while backup safety is uncertain

Management will want the 11:00 examination for 100 learners to run. The options are:

- **Option A: restore LMS01 and its FS01 content from the E05 backup now.** Rejected. E05 ran 25 minutes after the unexplained svc_backup logons (E03). The backups are not immutable and have not been restore-tested in 90 days. Restoring onto the network before credentials are reset could reintroduce the attacker, and the integrity of assessment content and submissions could not be assured.
- **Option B: postpone the examination (default).** This protects learners from an unfair or invalid sitting and avoids rushed restoration. The impact falls on 100 learners and on scheduling, which the BCP manages through a new date and clear communication.
- **Option C: alternative delivery.** Run the examination on a separate platform that does not depend on FS01, LMS01 or potentially compromised identities, using a clean copy of the paper. This is viable only if the academic owner confirms that the paper was not stored on FS01 or exposed through E04 (A15), and that assessment regulations permit the change.

The recommendation is B, with C acceptable if its conditions are confirmed by 09:45. Reopening LMS01 is permitted only when the acceptance criteria in Table 13 are met, which is not realistic before 11:00.

The executive sponsor makes the decision and the business owner records it, so that the CSIRT is not left carrying a business risk decision.

D. Create an evidence register for at least four relevant items. Record ID, source, proposed collection method, collector role, date and time with timezone, integrity check, secure storage, and custody transfers. Describe access restrictions. Use planned or not yet collected where appropriate; do not invent hashes or claim acquisitions you did not perform.

ANSWER

Evidence Registers

ID	Source	Proposed collection	Collector	Date/time (WAT)	Integrity check	Secure storage	Custody transfers
EV-01	FIN-PC07 memory and EDR triage (E01, E04, E06)	EDR live response and memory acquisition before or immediately after containment	Security analyst	Planned: Day 0 08:50–09:00 WAT	SHA-256 at acquisition (not yet computed)	Encrypted evidence drive in a locked safe; copy on isolated evidence storage outside FS01	Analyst → forensics lead (IT staff 3) → DFIR provider
EV-02	FIN-PC07 full disk image	Forensic image via write-blocker or DFIR tool after containment	DFIR provider, witnessed by the forensics lead	Planned: Day 0 10:00–12:00 WAT	SHA-256 of image (not yet computed)	As EV-01	DFIR → forensics lead for storage
EV-03	M365 sign-in and unified audit logs, finance account (E02)	Export from the admin portal (CSV/JSON); retention period checked	Security analyst	Planned: Day 0 09:00–09:15 WAT	SHA-256 of export files (not yet computed)	Isolated evidence storage; read-only	Analyst → forensics lead
EV-04	Proxy and firewall logs for the 1.2 GB transfer (E04)	Export of the relevant time window, 16:00 Day −1 to 09:30 Day 0	Security analyst	Planned: Day 0 09:10–09:20 WAT	SHA-256 of export (not yet computed)	Isolated evidence storage	Analyst → forensics lead → DFIR

E. Describe how you will remove persistence, address the likely entry point, and secure compromised credentials. Set recommended restoration order, recovery targets, and acceptable data loss. Explain how you will select and validate a backup, restore in a controlled

environment, check data integrity, and monitor for recurrence before the business owner approves service return.

ANSWER

Eradication

Persistence. The persistence mechanisms found by the scoping checks (Section 3.1.1) are removed. These may include services, scheduled tasks, run keys, remote access tools, rogue accounts and malicious OAuth consents. Compromised hosts are rebuilt from known-good images rather than cleaned, because the malware family and its capabilities are unconfirmed (E06). FIN-PC07 is reimaged only after EV-01 and EV-02 are acquired.

Entry point. The working hypothesis is that the E01 payroll attachment was the entry point. Validation comes through EV-02 and EV-07, and if it is not confirmed the entry point stays open as a finding. Actions include blocking the sender and attachment indicators, purging matching messages from all mailboxes, tightening attachment filtering (blocking macros and executable content), and giving finance staff targeted phishing awareness (Table 9, item 6).

Credentials. The finance officer's password is reset with sessions revoked and MFA re-registered on a verified device (E02). svc_backup is retired and replaced by a new account with only the rights needed on BAK01. That account has no remote interactive logon to FS01 and a long, vaulted password, with an alert on use outside schedule (E03). All administrator, service and break-glass passwords are reset. If on-premises AD exists (A14), the krbtgt password is reset twice, with a gap for replication, to invalidate forged Kerberos tickets. MFA is enforced for all users and administrators, and legacy authentication is blocked. Resets are done from a clean administrative workstation so that the new credentials are not captured.

Restoration order and recovery targets

Restoration follows dependency and business priority:

1. Identity and security tooling: AD and M365 hardened, monitoring in place.
2. Clean backup infrastructure: rebuilt BAK01 or isolated recovery storage.
3. FS01: the portal-related shares first, because LMS01 depends on them (E07).
4. LMS01: materials and assessment submission.
5. Finance data and FIN-PC07.
6. Remaining shares and the incident contact list (E08), with an offline copy created.

Proposed recovery targets

Service	Proposed RTO (A16)	Proposed RPO / acceptable data loss
LMS01 (materials, submissions)	48 hours from 08:45 Day 0	Up to the validated restore point; at worst Day −3 17:00 (about 64 hours of changes)
FS01 portal-related shares	36 hours (precedes LMS01)	As above

FS01 finance and administrative shares	72 hours	As above; finance changes since Friday re-entered from source records
FIN-PC07	72 hours (rebuild)	No local data restored without scanning
Other shares	7 days	As above

Acceptable data loss. The only backup outside network reach is the Day −3 17:00 copy. Restoring from it loses changes made between Friday 17:00 and the onset of encryption around 08:30 on Monday, roughly 64 hours. Most of that period is a weekend, so the practical loss may be smaller (A17). The E05 backup (02:00 Day 0) would cut the loss to about six hours, but it was taken after the suspicious E03 activity. It may be used only if validation shows it is free of encryption, malware and attacker changes. If it passes, the business owner chooses between the two restore points on the basis of the validation evidence. Lost assessment submissions and finance entries are reconstructed from learner resubmission, email receipts and bank records, coordinated through the BCP.

Backup selection, validation and controlled restoration

Candidate backups are mounted read-only in an isolated recovery network with no route to production or the internet. Validation has five steps: (1) confirm the backup is readable and complete against the job catalogue (EV-06); (2) scan it with up-to-date anti-malware and with indicators from the investigation; (3) check for .locked files, ransom notes and unexpected executables or scripts; (4) compare file counts, sizes and sample hashes against the other restore point; and (5) restore a sample to a clean host and open the files. Restoration then rebuilds FS01 and LMS01 on clean, patched operating systems, restores data only (not system state from a possibly compromised host), and applies the new credentials. The academic and finance owners check data integrity by sampling course materials, assessment records and finance files against known references. Once a restore point is chosen, the snapshot that was used is preserved as evidence.

Monitoring for recurrence. After service returns, EDR (extended to the restored servers), M365 sign-in alerts and proxy monitoring are watched closely for at least 14 days. Alerts are set for the known indicators, for svc_backup or any retired credential, for logons from the E02 IP address, and for traffic to the E04 destination. Any recurrence returns the incident to containment.

Recovery acceptance criteria

The business owner approves the return of each service only when every criterion in Table 13 is met and evidenced. The incident manager presents the evidence; the business owner signs. This keeps execution and approval separate, as in the RACI matrix (Table 8, activity 8).

Recovery acceptance criteria (all required before business owner approval)

#	Criterion	Evidence of completion	Verified by

AC1	Restore source validated clean (all five checks passed)	Validation report naming the restore point	Forensics lead
AC2	Host rebuilt on clean, patched OS with EDR active	Build record; EDR console showing the host healthy	IT operations lead
AC3	Credentials reset; svc_backup retired; MFA enforced	Reset log; conditional access report	Security analyst
AC4	No indicators of compromise on restored systems for an agreed observation period (e.g. 24 hours in isolation)	EDR and log hunt results	Security analyst
AC5	Data integrity confirmed by business sampling	Signed sample checklist	Business owner (Academic / Finance)
AC6	Functional tests pass: learner logon, materials open, test submission saved and retrievable	Test script results	Business owner (Academic)
AC7	Backups of the restored system run successfully to protected storage	First post-restore backup verified	IT operations lead
AC8	Monitoring and alerting for recurrence in place	Alert rule list; test alert fired	Security analyst
AC9	Communication to users approved	Approved notice (Task 4)	Communications lead / executive sponsor

Task 4 Communication and escalation

10 marks

A. Create a communication matrix for at least six stakeholder groups. Record trigger, message owner, channel, approver, and update frequency. Include learners, management, IT or security staff, a relevant service provider, and legal or privacy advisers. Provide an alternative channel if corporate email is unsafe or unavailable.

ANSWER

Communication matrix

Stakeholder group	Trigger	Message owner	Channel (email unsafe until verified)	Approver	Update frequency

Executive / management (executive sponsor, senior leaders)	Critical declaration (08:45); any severity change; decisions needing approval	Incident manager	Phone call and conference bridge; written briefing on the out-of-band messaging group	Incident manager (factual accuracy)	Hourly during the first 24 hours; immediately on escalation triggers
CSIRT, IT and security staff	Activation; each new action or finding	Incident manager	Staff phones; encrypted messaging group; offline incident log	Incident manager	Continuous; formal stand-up every 2 hours
All staff	Service disruption confirmed; phishing risk (E01)	Communications lead	Phone cascade by line managers; SMS; noticeboards; email only once verified	Executive sponsor	By 10:00, then twice daily
Learners (including the 100 examination candidates)	Examination decision (09:45); service status changes	Communications lead with the business owner (Academic)	SMS; website status page; helpline; LMS banner after restoration	Executive sponsor	Initial notice by 10:15; then at 16:00 daily or on change
Service providers (DFIR firm, Microsoft support, backup vendor / MSP)	Engagement (Table 10, row 9); support needed	Incident manager	Provider hotline by phone; provider portals from a clean device	Incident manager (executive sponsor approves spending)	As agreed per engagement; at least every 4 hours
Legal / privacy advisers (DPO, external counsel)	Possible personal data exposure (E02, E04); ransom or extortion contact	Incident manager	Phone; encrypted messaging; secure document sharing outside FS01	Executive sponsor	Immediate briefing; then every 4 hours or on new data findings
Cyber insurer (if a policy exists, A7)	Critical declaration; before engaging costed third parties	Executive sponsor	Insurer's incident hotline (from the offline contact list)	Executive sponsor, advised by legal	On engagement; then as the policy requires
Regulator (NDPC), national CERT and police	Legal adviser determines a notification or reporting duty, or a decision to report a crime	Legal / privacy adviser	Official portal or the regulator's published contact route	Executive sponsor	As the law or the authority requires
Media and public	Media enquiry; social media	Communications lead	Holding statement on the website;	Executive sponsor, after legal review	On enquiry; holding line updated daily

	claims; attacker publication threat		nominated spokesperson only		

B. Draft a 150 to 200 word executive briefing with confirmed impact, uncertainty, decisions requiring approval, and the next update time. Draft a separate 100 to 150 word learner notice with practical instructions and the status of the examination.

ANSWER

Executive briefing

Executive briefing: Critical incident, 09:40 WAT, Day 0. Prepared by the Incident Manager; restricted.

Confirmed impact: Files on the finance workstation FIN-PC07 and the shared file server FS01 have been encrypted, and a ransom note was found; we are treating this as ransomware. The learning portal cannot deliver materials or accept submissions, and the incident contact list is unavailable. Affected systems have been isolated and the backup service account disabled.

Uncertain: We do not yet know whether personal or assessment data was stolen; a 1.2 GB upload to unfamiliar cloud storage is under investigation. A finance user account may be compromised, so corporate email is not trusted. Our backups may also be affected, and none has yet been validated as clean.

Decisions requiring your approval: (1) Postpone the 11:00 examination for 100 learners; restoring the portal from an unverified backup risks reinfection and invalid results. (2) Engage our forensic provider and notify our insurer. (3) Authorise legal advisers to assess notification duties. (4) Confirm that no one contacts the attacker or discusses payment.

Next update: 10:45 WAT by conference bridge, or sooner if the situation changes.

Draft a separate 100 to 150 word learner notice with practical instructions and the status of the examination

Learner notice (SMS summary and website status page)

Important: Northbridge service disruption and examination update.

We are dealing with a cybersecurity incident that has disrupted the learning portal. Today's 11:00 online examination is postponed. No one will be penalised, and the new date and time will be confirmed by SMS and on our website.

Please:

- Do not reply to, open links in, or download attachments from unexpected messages about Northbridge, payments or your account, even if they look official.
- Use only our official channels: www.northbridge.example/status and the helpline on 000-000-0200.
- Never share your password or verification codes. We will never ask for them.

We are investigating whether any personal information has been affected and will contact you directly if it has. Next update: 16:00 WAT today.

C. Explain how legal or privacy advisers will assess notification obligations and confirm the relevant recipients and deadlines. Distinguish operational notices from any formal breach notification. If you assert a legal deadline, identify the jurisdiction and cite an authoritative source.

ANSWER

Assessing notification obligation

Operational notices and formal breach notifications are different instruments and are handled separately. Operational notices, such as the learner notice, staff updates and the holding statement, tell people what is happening and what to do. The communications lead owns them, the executive sponsor approves them, and they make no legal admission. Formal breach notifications are statutory or contractual communications whose content, recipient and timing are fixed by law or contract. The legal/privacy adviser owns them, the executive sponsor approves them, and they are recorded in the decision log together with the evidence relied on.

The legal/privacy adviser follows five steps:

1. **Confirm jurisdiction and role.** The working assumption is that Northbridge operates in Nigeria and acts as data controller for learner and staff data (A18). Learners or processors located elsewhere could bring other regimes into play.
2. **Decide whether a personal data breach has occurred.** A breach includes unauthorised access to, loss of or encryption of personal data, not only confirmed theft. The encryption of FS01 (E06) may itself qualify, because personal data was made unavailable. The E04 analysis (Q4, Task 1) determines whether confidentiality was also lost.
3. **Assess risk to individuals.** Consider the categories of data involved (contact details, admission documents, assessment records, finance data), the number of data subjects, and whether fraud or identity theft is plausible.
4. **Fix the awareness time and the deadlines.** Under section 40(2) of the Nigeria Data Protection Act 2023, a data controller must notify the Nigeria Data Protection Commission (NDPC) within 72 hours of becoming aware of a breach that is likely to result in a risk to individuals' rights and freedoms. Where feasible, the notification describes the nature of the breach and the approximate numbers of data subjects and records concerned (Nigeria Data Protection Act, 2023, s. 40(2)). Where the risk is high, affected data subjects must be informed immediately in plain language, with advice on protective measures (s. 40(3)). The NDPC's implementation directive repeats both duties and lists the expected content of a notification (NDPC, 2025, art. 33). For planning, awareness is conservatively fixed at 08:45 on Day 0, the time of the Critical declaration. That gives a latest NDPC notification time of 08:45 on Day +3 if the threshold is met. A notification can be made in phases as facts emerge, rather than waiting for certainty.
5. **Identify other recipients.** These include the insurer (policy terms, A7), any processor or partner with contractual notification clauses (A20), police if a crime report is decided, and the national CERT where advisers judge that reporting applies. CISA likewise recommends reporting ransomware

incidents and following the notification requirements in the response plan (CISA et al., 2023). Advisers confirm each recipient and deadline in writing; the matrix does not assume any of them.

Escalation rules

Trigger	Escalate to	Target time
Evidence of personal data exposure (e.g. E04 content identified)	Legal/privacy adviser and executive sponsor	Immediately; notification assessment starts
Ransom note contact, extortion message or publication threat	Executive sponsor, legal adviser and insurer; no staff engagement with the attacker	Within 15 minutes
Evidence that corporate email or M365 is compromised	Incident manager; all communications move to out-of-band channels	Immediately
Risk to any examination or assessment deadline	Business owner (Academic) and executive sponsor	At least 75 minutes before the start time
Backup found compromised or unrestorable	Incident manager, then executive sponsor (recovery targets reset)	Within 30 minutes
Media enquiry or viral social media claim	Communications lead, then executive sponsor; spokesperson only	Within 30 minutes
Scheduled update missed or approver unreachable	Next level up, or the named deputy (A8)	At the missed time

Task 5 Tabletop exercise and improvement plan

1. Design a 60 minute tabletop exercise that tests your plan. State objectives, participant roles, an agenda, and at least three measurable success criteria. Walk through the exercise individually, taking the role of each participant. Clearly label the results as a simulation.

Exercise time	Required inject
Minute 10	Management asks you to reopen the learning portal before the 11:00 examination, even if the most recent backup is unverified.
Minute 20	An attacker claims to hold all 1,800 learner records and threatens publication in 12 hours. A screenshot is provided, but its authenticity is unknown.

Minute 35	A test restoration of the latest network backup fails with an unreadable snapshot error.
Minute 45	A social media post claims the examination is cancelled. A journalist asks whether learner information has been exposed.

ANSWER

Tabletop Design

Title and scope. "Northbridge Day 0". This is a 60-minute, discussion-based tabletop that starts from the Task 1 position at 08:45 WAT on Day 0, with E01–E08 known. The scenario clock is compressed, so each inject carries a simulated scenario time. No live systems are touched (A21).

Objectives:

- O1. Confirm that the CSIRT can activate and coordinate using only out-of-band channels.
- O2. Test executive and business-owner decision authority on examination access while backup safety is uncertain.
- O3. Test extortion handling and the start of the notification assessment under NDPA s. 40 (Nigeria Data Protection Act, 2023; Section 4.3).
- O4. Test recovery replanning when the preferred backup fails.
- O5. Test public communication and misinformation response

Exercise role	Played by (A22)	Purpose
Facilitator (exercise director)	Author / exercise designer	Delivers injects, keeps time, role-plays external parties (attacker, journalist, DFIR provider, Microsoft) as the "white cell".
Evaluator and scribe	Deputy Principal (executive sponsor's deputy)	Times each decision, records the decision log, scores success criteria; also familiarises the deputy with the plan.
Executive sponsor	Principal / Chief Executive	Decisions on examination, extortion, spending, external statements.
Incident manager (IRL)	IT Manager	Coordination, containment authority, decision log.
Security analyst	Security analyst	Scoping and identity investigation.
Forensics lead / evidence custodian	IT staff 3	Evidence register and custody.
IT operations lead	IT staff 2	Backup, restoration and credential actions.

Business owners	Head of Academic Operations; Finance Manager	Examination continuity; finance impact; restoration approval.
Legal / privacy adviser	Data Protection Officer	Notification assessment; extortion and media advice.
Communications lead	Marketing and Communications Officer	Learner, staff and media messages.

Agenda (60 minutes)

Exercise minute	Scenario time (simulated, WAT)	Module / inject	Discussion focus
0–5	08:45 Day 0	Briefing: ground rules, objectives, E01–E08	No-fault discussion; the decision log is live
5–10	08:45–09:20	Module 1: activation and containment	Playbook rows 1–7 (Table 10); out-of-band channels
10–20	09:30	Inject 1 (required): management asks for the portal to be reopened before 11:00 from an unverified backup	Authority, Option A/B/C, Table 13
20–35	11:30	Inject 2 (required): attacker claims all 1,800 learner records; publication in 12 hours; unverified screenshot	Extortion, evidence, NDPA s. 40, insurer
35–45	18:00	Inject 3 (required): test restore of the latest network backup fails, unreadable snapshot	Recovery replanning, data loss, RTO
45–50	19:00	Inject 4 (required): social media says the exam is cancelled; journalist asks about learner data	Correction, holding statement, legal review
50–55	20:30	Inject 5 (own): Finance Manager receives an MFA push they did not initiate	Wider identity compromise, scope
55–60	–	Hot wash: success criteria, top improvements, feedback form	Owners and dates for actions

Measurable success criteria

ID	Success criterion	Target / measure

SC1	Every inject produces a logged decision with exactly one named owner within 5 minutes of the inject.	7 of 7 decisions
SC2	No decision authorises restoring LMS01 from a backup that has not met Table 13 (AC1).	Zero unsafe restorations
SC3	Within 5 minutes of Inject 2, legal/privacy records an awareness time and starts the NDPA assessment, and no one contacts the attacker without executive authority.	Both conditions met
SC4	Within 10 minutes of Inject 4, a correction and a holding statement are approved by the executive sponsor and issued through the Table 14 channels, without corporate email.	≤10 minutes; correct channel

2. Add one further inject of your own. Record at least five decisions in a log with inject, decision, decision owner, rationale, communication, and effect on the response or recovery plan.
ANSWER

SIMULATION - Module 1 (minutes 5–10)

- **Incident manager:** I declare a Critical incident, open the offline log and activate the CSIRT by phone
- **Security analyst:** I contain FIN-PC07 through EDR after the triage capture (EV-01) and export the finance officer's sign-in logs before revoking sessions (EV-03).
- **IT operations lead:** I isolate FS01, disable svc_backup and suspend BAK01 jobs. I report that LMS01 is now fully offline.
- **Forensics lead:** I open the evidence register and custody forms for EV-01 to EV-07; nothing has been hashed yet.
- **Communications lead:** The CSIRT messaging group is live, and corporate email is not used.

SIMULATION - Inject 1 – minute 10 (scenario 09:30)

- **Executive sponsor (receiving the management request):** Could we restore last night's backup and run the exam?
- **IT operations lead:** That backup (E05) ran 25 minutes after the unexplained svc_backup logons (E03) and has not been validated. It fails AC1.
- **Business owner (Academic):** I cannot confirm where the paper is stored (A15), so Option C is unsafe. I recommend postponement with no penalty to learners.
- **Executive sponsor:** I decline the request and approve postponement (D1). Communications lead, issue the learner notice in Section 4.2.

SIMULATION - Inject 2 – minute 20 (scenario 11:30)

- **Legal / privacy adviser:** The claim is unverified, but it is credible given E04, so I am recording our awareness time as 08:45. I am starting the s. 40 assessment; the attacker's 12-hour deadline does not set our legal timetable.
- **Forensics lead:** I am registering the screenshot and the attacker's message as a new evidence item, EV-08.
- **Security analyst:** I will compare the screenshot's fields and record counts with our data stores and the 1.2 GB transfer (D3).
- **Executive sponsor:** No one engages the attacker. I am notifying the insurer, and legal will advise on reporting to police. CISA does not recommend paying (CISA et al., 2023) (D2).

SIMULATION - Inject 3 – minute 35 (scenario 18:00)

- **IT operations lead:** The unreadable snapshot means the network backups cannot be trusted. I propose we quarantine BAK01 as evidence and fall back to the Day −3 offline copy.
- **Incident manager:** Agreed. The LMS01 RTO in Table 12 is at risk: we have never timed a restore from offline media.
- **Business owner (Academic):** I accept the loss of about 64 hours of changes. I will ask learners who submitted work over the weekend to resubmit (D4).
- **Executive sponsor:** The revised RTO of 72 hours for LMS01 is noted, and the next briefing will report it.

SIMULATION - Inject 4 – minute 45 (scenario 19:00)

- **Communications lead:** I have drafted the correction: "The exam is postponed, not cancelled; a new date will follow by SMS and on our status page." For the journalist: we are investigating, we cannot yet confirm whether learner data is affected, and we will contact anyone affected directly.
- **Legal / privacy adviser:** Neither statement admits or denies a breach. Both are compatible with a possible s. 40(3) notice to learners later.
- **Executive sponsor:** I approve both (D5). The website update was delayed: the status page administrator login depends on Microsoft 365 single sign-on, which is under suspicion (A23). The message went out by SMS first.

SIMULATION - Inject 5 – minute 50 (scenario 20:30)

- **Business owner (Finance):** I have just received a sign-in approval request I did not start. I denied it.
- **Security analyst:** This suggests the attacker holds a second password. I recommend blocking the account, revoking sessions and resetting the password from a clean device, then hunting the tenant for sign-ins from the E02 address.
- **Incident manager:** I briefly questioned whether disabling a business owner's account needed approval. The analyst cited Section 2.1, which gives authority without prior approval for credible identity compromise. I authorised the action (D6) and the all-staff warning by SMS (A24).

#	Inject	Decision	Decision owner	Rationale	Communication	Effect on response / recovery plan

D1	Inject 1: reopen portal from unverified backup	Decline; postpone the 11:00 exam (Option B); Option C rejected pending A15	Executive sponsor	E05 unvalidated after E03; AC1 not met; risk of reinfection and invalid results	Learner notice by SMS and website; management briefing	BCP owns the new exam date; restoration order unchanged
D2	Inject 2: claim of 1,800 records and 12-hour threat	Treat as unverified but credible; no engagement or payment; notify insurer; legal starts s. 40 assessment with awareness time 08:45	Executive sponsor	Consistent with E04 but unproven; the legal timetable is independent of the attacker's deadline	Insurer and legal by phone; no public statement yet	Q4 raised to top priority; planned NDPC latest time 08:45 Day +3 if the threshold is met
D3	Inject 2: screenshot authenticity	Register the screenshot as EV-08; compare fields and counts with FS01/LMS01 data and the E04 volume	Forensics lead	Evidence-based answer needed before any statement to learners or the regulator	Findings to legal and incident manager	Evidence register (Table 11) gains EV-08
D4	Inject 3: network backup restore fails	Quarantine BAK01 as evidence; restore from the Day −3 offline copy after validation; accept about 64 hours of data loss	Business owner (Academic)	Network backups untrustworthy; the offline copy is the only candidate	Executive sponsor briefing; learners asked to resubmit weekend work	LMS01 RTO revised from 48 to 72 hours in Table 12; escalation rule (Table 15) applied
D5	Inject 4: social media and journalist	Approve the correction and holding statement; SMS first, then website; spokesperson only	Executive sponsor	Stop misinformation without admitting or denying a breach	SMS, status page, journalist by phone	Media updates daily; social monitoring added to the communications lead's log
D6	Inject 5: unapproved MFA push	Block the Finance Manager account, revoke sessions, reset from a clean device; tenant-wide hunt; all-staff SMS warning	Incident manager	Credible second identity compromise; Section 2.1 authority	Finance Manager by phone; staff SMS	Scope widened; Q2 broadened; email stays untrusted; Critical retained
D7	Hot wash	Adopt the improvement plan (Table 21); after-action report within 5 working days	Executive sponsor	Close gaps found in SC1, SC4 and SC5	CSIRT messaging group; plan owner	Plan revision triggered (Section 2.1, plan review)

3. Evaluate the simulated results against your success criteria. Identify at least five improvements and give each a priority, owner, target completion time, and measurable evidence of completion. Set a post incident review deadline and explain who closes the actions.
   ANSWER

Evaluation against success criteria (Simulation)

Table 20. Evaluation (SIMULATION)

Criterion	Result	Evidence from the simulated log
SC1	Partly met	6 of 7 decisions were made within 5 minutes. D6 took about 7 minutes because the isolation authority in Section 2.1 was not recalled under pressure.
SC2	Met	D1 and D4 both kept restoration behind AC1; no unsafe restoration was proposed after the first discussion.
SC3	Met	The awareness time was recorded and the assessment started within 3 minutes; no contact with the attacker.
SC4	Partly met	Approved in 8 minutes, but the website update was delayed to about 14 minutes by its dependency on M365 single sign-on (A23); SMS met the target.
SC5	Partly met	The fallback was agreed in 4 minutes and data loss was acknowledged, but the revised RTO is an estimate because no offline restore has ever been timed.

Overall, the plan held on the two highest-risk judgements: it did not reopen the portal on an unverified backup, and it did not let the attacker's deadline drive the legal assessment. The weaknesses were practical rather than conceptual. Authority was not recalled quickly, a hidden dependency on Microsoft 365 affected public communication, and recovery timings were untested. These findings reinforce readiness items 1, 3 and 6 in Table 9 and add new actions.

Limitations of a single-author simulation. Because one person played every role, this simulation cannot reproduce real disagreement, fatigue or gaps in knowledge, and it probably flatters the result for SC2 and SC3. The timings are also estimates rather than measurements. A live exercise with the actual role holders is therefore required before any criterion is treated as genuinely met. The improvement plan builds that retest in, and the next exercise should introduce injects that the participants have not seen in advance.

Improvement Plan

The improvement plan converts the findings into actions. Priority reflects the risk if the gap recurred during a real incident: High items affected a success criterion or the recovery path directly.

Improvement plan

#	Priority	Improvement	Owner	Target completion	Measurable evidence of completion
1	High	Timed test restore of FS01 and LMS01 from offline media in the isolated environment	IT operations lead	30 days	Signed test record with measured duration compared against Table 12 RTOs
2	High	Remove website and SMS admin dependency on M365 single sign-on; break-glass credentials kept offline	Communications lead with IT operations lead	14 days	Successful status page update during a test with M365 sign-in disabled
3	High	One-page authority card summarising Section 2.1 and Table 6 for every CSIRT member and deputy	Incident manager	14 days	Card issued to all 8 roles and deputies; next exercise decision time ≤5 minutes
4	High	Phishing-resistant MFA or number matching; alerts on repeated push prompts	Security analyst	30 days	Conditional access report; simulated prompt flood triggers an alert within 15 minutes
5	Medium	Extortion and leak-claim verification procedure (evidence item, comparison method, insurer and legal steps)	Legal / privacy adviser with forensics lead	30 days	Procedure approved by the executive sponsor; used in the next exercise
6	Medium	Pre-approved templates: exam postponement, misinformation correction, data-investigation holding statement	Communications lead	21 days	Templates approved by the executive sponsor and legal; stored offline
7	Medium	Examination continuity procedure, including paper storage separate from FS01 and an alternative delivery option	Business owner (Academic)	60 days	Procedure approved; paper storage location documented (resolves A15)
8	Low	Automated backup integrity verification on BAK01 with failure alerts	IT operations lead	60 days	Weekly verification report; a test failure produces an alert

Review deadline. The evaluator and incident manager issue the after-action report within 5 working days of the exercise, using the CTEP after-action report and feedback form templates (CISA, n.d.). For a real incident, the post-incident review is held within 10 working days of closure (Table 10, row 18).

Who closes actions. Each action owner implements the improvement and submits the evidence listed in Table 21. The incident manager keeps the improvement register, checks the evidence and reports progress monthly to the executive sponsor. In line with the RACI matrix (Table 8, activity 9), the executive sponsor is accountable for closing each action. An action is closed only when its evidence has been verified, never on a verbal assurance. Overdue High actions are escalated at the next management meeting. Completed actions trigger the plan review in Section 2.1, and the next tabletop retests SC1, SC4 and SC5. This closes the improvement loop that NIST describes, with lessons feeding all functions (Nelson et al., 2025).

Task 6 Case study analysis and critical reflection

Write 300 to 400 words analysing the illustrative healthcare ransomware case on slide 16 of the teaching deck. Identify three response strengths and two limitations or unresolved issues. Explain two changes you would transfer to the Northbridge plan and justify their relevance.

Discuss why restoring critical systems within 72 hours differs from full restoration over seven days. Explain what evidence would be needed before claiming that no patient data was stolen. Identify one decision in your own plan that you would revise after the tabletop exercise.

ANSWER
Response Strengths

The illustrative healthcare case shows three strengths (ICDFA, n.d., slide 16). First, offline backups were verified intact during containment on Day 4, before recovery depended on them, which removed the pressure to pay. Second, segmentation and a pre-established team allowed isolation immediately after the EDR alerts. Third, the response closed the loop: on Day 14 the organisation updated its plan, scheduled training and shared threat intelligence with ISAC partners.

Limitations and unresolved issues

First, detection failed for 72 hours. Persistence and lateral movement went unnoticed, and the EDR alerts apparently came only when encryption began (inference, A25). Ryuk has typically been deployed after loaders such as TrickBot, whose capabilities include data exfiltration (CISA et al., 2020). Against that background, “no patient data exfiltration confirmed” is ambiguous: the slide does not show whether exfiltration was ruled out or simply not found. Second, several claims lack visible evidence. “Malware fully removed” within three days is not supported on the slide. Backups are described as tested, yet testing “revealed restoration gaps”. No notification dates are given to support the claim that notifications were “on time”.

Changes transferred to Northbridge

I would transfer offline or immutable backups with timed restore tests (Table 9, item 1; improvement I1). They address Northbridge’s central weakness: network backups that are neither immutable nor tested, and that may be compromised (E03, E05). I would also transfer server EDR and segmentation, because Northbridge’s overnight attacker activity (E02–E05) went undetected until encryption, as in the case.

Critical systems in 72 hours verus full restoration in seven days

The first figure is a tiered recovery target. Priority services return on validated, rebuilt infrastructure, while other systems, data reconciliation and monitoring continue until full restoration. Residual risk remains throughout, so each tier needs its own acceptance check.

Evidence needed before claiming no patient data was stolen

The organisation would need proxy, firewall, NetFlow and DNS logs covering the whole dwell period. It would also need EDR telemetry for staging or archiving tools such as rclone or 7-Zip, cloud-storage audit logs and forensic images of the affected hosts. Any log-retention gaps must be declared. The absence of a leak-site listing is not proof.

Decision revised after the tabletop

I would revise the 48-hour LMS01 RTO (Table 12). It assumed a restore speed Northbridge has never measured, so I would set 72 hours until timed offline restoration (I1) proves otherwise (Table 21).

References

Cybersecurity and Infrastructure Security Agency. (n.d.). *CISA tabletop exercise packages*. Retrieved October 19, 2026, from https://www.cisa.gov/resources-tools/services/cisa-tabletop-exercise-packages

Cybersecurity and Infrastructure Security Agency, Federal Bureau of Investigation, & Department of Health and Human Services. (2020). *Ransomware activity targeting the healthcare and public health sector* (Cybersecurity Advisory AA20-302A). CISA. https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-302a

Cybersecurity and Infrastructure Security Agency, Multi-State Information Sharing and Analysis Center, National Security Agency, & Federal Bureau of Investigation. (2023). *#StopRansomware guide* (Version 3.0). CISA. https://www.cisa.gov/resources-tools/resources/stopransomware-guide

International Cybersecurity and Digital Forensics Academy. (n.d.). *Incident response planning* [PowerPoint slides 1–18]. GRC105 Incident Management and Business Continuity, Week 20, ICDFA Training Program.

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST Cybersecurity White Paper 29). https://doi.org/10.6028/NIST.CSWP.29

Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). *Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile* (NIST Special Publication 800-61r3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r3

Nigeria Data Protection Act, 2023, No. 37 (Nigeria). https://www.ndpc.gov.ng/ndp-act-2023/

Nigeria Data Protection Commission. (2025). *Nigeria Data Protection Act 2023 general application and implementation directive (GAID) 2025* (NDPC/NDP ACT-GAID/01/2025). https://ndpc.gov.ng/wp-content/uploads/2025/03/NDP-ACT-GAID-2025-MARCH-20TH.pdf